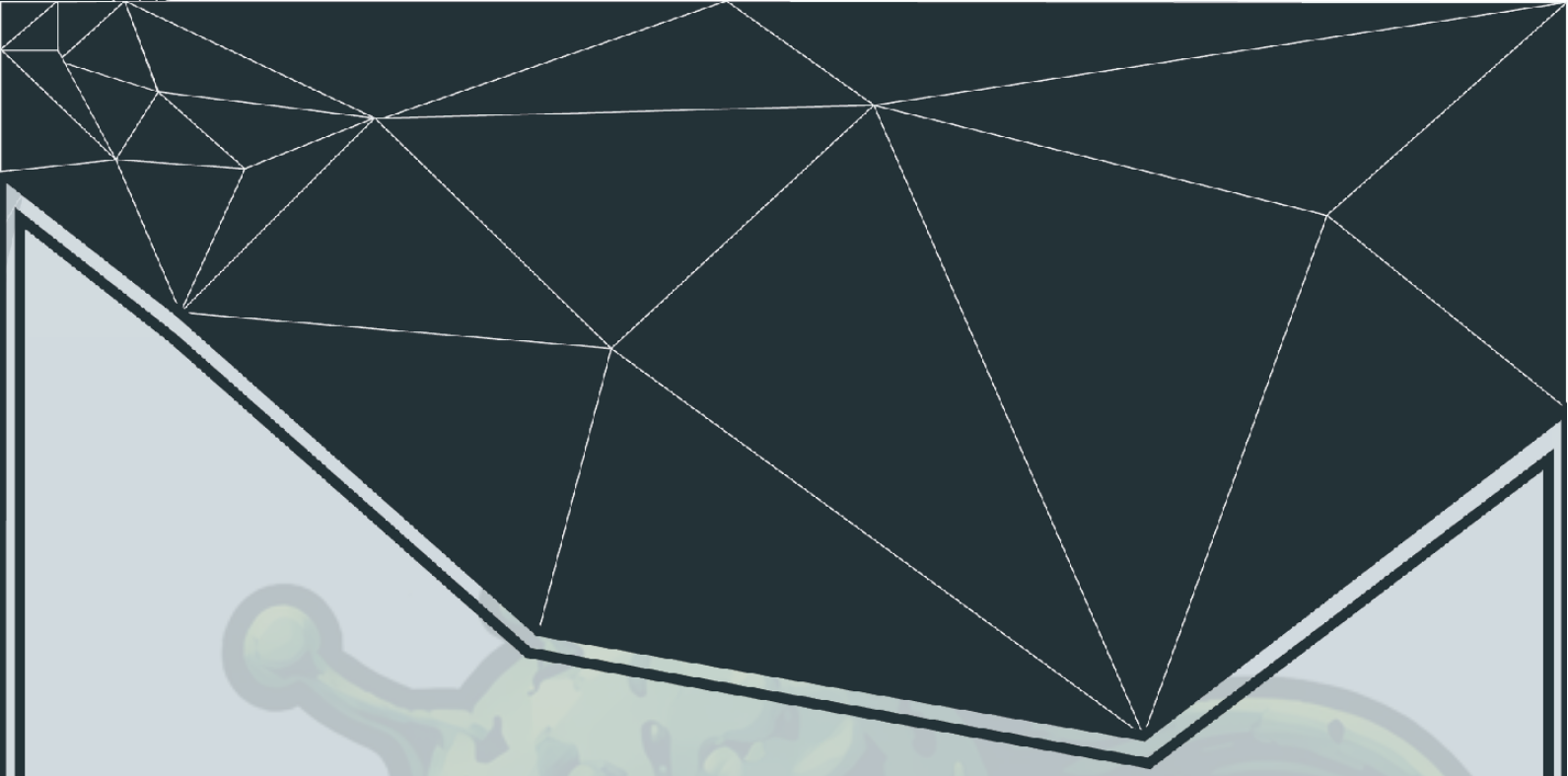




NESHTA

TEKNİK ANALİZ RAPORU

ZAYOTEM

ZARARLI YAZILIM ÖNLEME VE TERSİNE MÜHENDİSLİK

İçindekiler

Ön Bakış.....	1
neshta.exe Analizi.....	2
Statik Analiz.....	2
Dinamik Analiz.....	3
Temp'e Bırakılan Dosyanın Analizi.....	9
YARA Kuralı.....	12
MITRE ATTACK TABLE.....	13
Çözüm Önerileri.....	13
HAZIRLAYAN.....	14

Ön Bakış

Neshta malware ailesi, Windows sistemleri hedef alan ve ağırlıklı olarak “**file infector**” (dosya enfektörü) olarak sınıflandırılan bir zararlı yazılımdır. İlk olarak 2000’li yılların ortalarında tespit edilen bu zararlı, genellikle enfekte edilmiş çalıştırılabilir dosyalar ve taşınabilir medya aracılığıyla yayılır. Neshta, bulaştığı sistemlerde dosya bütünlüğünü bozarak kalıcılık sağlamayı ve sistem üzerinde gizlice çalışmayı amaçlar.

Bu kötü amaçlı yazılımın virüs bulaştırdığı bilgisayarlarda;

- Çalıştırılabilir (.exe) dosyalarını enfekte etmesine,
- Sistem başlangıç mekanizmalarını manipüle ederek kalıcılık sağlamasına,
- Temel sistem bilgilerini (bilgisayar adı, kullanıcı adı, işletim sistemi bilgisi) toplamasına,
- Dosya yapılarında değişiklik yaparak tespiti zorlaştırmasına,
- Meşru uygulamaların çalışma akışını bozmasına

olarak sağladığı bilinmektedir.

neshta.exe Analizi

Adı	Light Tool V9.exe
MD5	10812383882408c1d898b07d29d6e940
SHA256	4cc12d29c4de4d3316ed62add841d20e66bbd5419cd8011e774f937f201be72b
Dosya Türü	PE32/EXE

Statik Analiz

Property	Value
File Name	C:\Use~1\p\Desktop\neshta.exe
File Type	Portable Executable 32
File Info	Borland Delphi 4.0
File Size	962.50 KB (985600 bytes)
PE Size	40.50 KB (41472 bytes)
Created	Sunday 30 November 2025, 21.18.47
Modified	Sunday 30 November 2025, 18.18.02
Accessed	Sunday 30 November 2025, 21.18.47
MD5	10812383882408C1D898B07D29D6E940
SHA-1	9E0791ADE2278F01659B813F259EDF8FC89EB8B9

Şekil 1 – neshta.exe Dosyasının Statik Analizi

Dosyaya statik analiz araçları ile bakıldığında 32-bit PE olduğu ve Delphi ile derlendiği gözükmemektedir. Buna ek olarak **File Size** ve **PE Size** arasında büyük bir farklılık bulunmaktadır. Bu şüpheli olarak nitelendirilen bir davranış ve birçok sebebi olabilir:

- Runtimedaki unpack etmek üzere kodu packleme,
- AntiVirüs yazılımlarını atlatmak için dosyayı çöp veri ile doldurma,
- İçerisinde başka bir .exe, .dll , shellcode barındırma.

Ofset	Boyut	Tip	Kelime
257	0000a0e0	00000044 A	Delphi-the best. Fuck off all the rest. Neshta 1.0 Made in Belarus.

Şekil 2 – String Analizi

Dosyanın string tablosuna bakıldığında da **Neshta** ailesine ait olduğu doğrulanmaktadır.

Dinamik Analiz

Döküm1	Döküm2	Döküm3	Döküm4	Döküm5	İzle 1
Adres	Hex	Hex	Hex	Hex	ASCII
004091E0	2B 5E FE 90	C7 BA E3 57	97 CB 0B 90	B5 E1 D9 6E	+^p.Ç°āw.Ē..µāŪn
004091F0	CA 12 58 FD	B1 15 2E 9A	74 DB 4E F3	C4 9E 74 93	Ē.xý±...t0NóA.t.
00409200	EE E2 68 EE	11 84 8B C0	60 88 B2 F2	54 F8 35 FD	îâhî...A`.°ôTø5ý
00409210	9C 91 40 00	08 90 40 00	00 00 00 00	00 00 00 00	..@...@.....
00409220	00 00 00 00	00 00 00 00	00 00 00 00	00 00 00 00	

Şekil 3 – Mutex’in İçindeki Şifreli Metin

Dosya ilk olarak bir **mutex** oluşturmaktadır. Mutex’in yazılacağı bölgede “+^p.Ç°āw.Ē.” şifreli metni bulunuyor.

0040708D	85DB	test ebx,ebx
0040708F	7E 10	jle neshta.4070A1
00407091	B8 FF000000	mov eax,FF
00407096	E8 E5B5FFFF	call neshta.402680
0040709B	3006	xor byte ptr ds:[esi],al
0040709D	46	inc esi
0040709E	4B	dec ebx
0040709F	75 F0	jne neshta.407091
004070A1	5E	pop esi

Şekil 4- XOR Döngüsü

Daha sonra buradaki her karaktere, sırasıyla AL değeri ile XOR işlemi yapılıyor.

00402680	53	push ebx
00402681	31DB	xor ebx,ebx
00402683	6993 08904000 0584080	imul edx,dword ptr ds:[ebx+409008],8088405
0040268D	42	inc edx
0040268E	8993 08904000	mov dword ptr ds:[ebx+409008],edx
00402694	F7E2	mul edx
00402696	89D0	mov eax,edx
00402698	5B	pop ebx
00402699	C3	ret

Şekil 5 – AL Değerinin Güncellendiği neshta.402680 Fonksiyonu

AL değeri döngünün her adımında değişiyor ve bunu belirleyen de **neshta.402680** fonksiyonu. Bu iç fonksiyonda önceki **state**, **state = state * 0x08088405 + 1** formülüyle güncelleniyor, sonra state kendisiyle çarpılıp üst 32 bit’i alınıyor; bunun **AL** kısmı bir sonraki **XOR** anahtarı oluyor. Kullanılan ilk **AL** değeri döngünün başında ayarlanmaktadır.

 Döküm1	 Döküm2	 Döküm3	 Döküm4	 Döküm5	 İzle 1
Adres	Hex				ASCII
004091E0	73 76 63 68	6F 73 74 2E	63 6F 6D 90	B5 E1 D9 6E	svchost.com.máun
004091F0	CA 12 58 FD	B1 15 2E 9A	74 DB 4E F3	C4 9E 74 93	É.Xý±...t0NóÁ.t.
00409200	EE E2 68 EE	11 84 8B C0	60 88 B2 F2	54 F8 35 FD	îâhî...À`.²òTø5ý
00409210	9C 91 40 00	08 90 40 00	00 00 00 00	00 00 00 00	..@...@.....

Şekil 6 – Deşifreleme Sonrası Yazılan svchost.com

Bu işlem sonucu mutex içerisine “svchost.com” yazılıyor.

75A12F6B	8BFF	mov edi,edi	GetModuleFileNameA
75A12F6D	55	push ebp	
75A12F6E	8BEC	mov ebp,esp	
75A12F70	83EC 10	sub esp,10	
75A12F73	57	push edi	
75A12F74	E8 383DFFFF	call <kernelbase.KernelBaseGetGlobalData	
75A12F79	8B7D 10	mov edi,dword ptr ss:[ebp+10]	
75A12F7C	8B40 2C	mov eax,dword ptr ds:[eax+2C]	
75A12F7F	64:8B00 18000000	mov ecx,dword ptr [18]	
75A12F86	8D43F	lea edx,dword ptr ds:[edi+edi]	
75A12F89	52	push edx	
75A12F8A	50	push eax	
75A12F8B	8B41 30	mov eax,dword ptr ds:[ecx+30]	
75A12F8E	FF70 18	push dword ptr ds:[eax+18]	
75A12F91	FF15 1810A075	call dword ptr ds:[<Krt1A11locateHeap>]	
75A12F97	8945 FC	mov dword ptr ss:[ebp+4],eax	[ebp-4]:L"C:\Users\ o\Desktop\neshta.exe"
75A12F9A	85C0	test eax,eax	
75A12F9C	75 11	jnz kernelbase.75A12FAE	

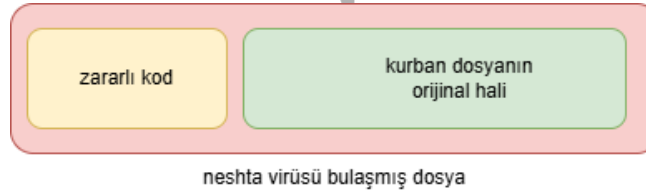
Şekil 7 – Dosya Adının Alınması

Masaüstünde bulunan dosya, daha sonra GetModuleFileNameA API’i ile çalışan dosyanın adına erişmektedir.

75A65D8A	8BFF	mov edi,edi	CreateFileA
75A65D8B	55	push ebp	
75A65D8C	8BEC	mov ebp,esp	
75A65D8E	51	push ecx	
75A65D90	51	push ecx	
75A65D92	FF75 08	push dword ptr ss:[ebp+8]	
75A65D95	8045 F8	lea eax,dword ptr ss:[ebp-8]	
75A65D98	50	push eax	
75A65D9C	E8 A1EAF0FF	call <kernel32.Basep88itStringToDynamicC	
75A65D9F	85C0	test eax,eax	
75A65DA2	0F84 24990200	jz kernel32.75A8F6F5	
75A65DA5	56	push esi	
75A65DA8	FF75 20	push dword ptr ss:[ebp+20]	
75A65DAB	FF75 1C	push dword ptr ss:[ebp+1C]	
75A65DAD	FF75 18	push dword ptr ss:[ebp+18]	

Şekil 8 – Temp Altına Oluşturulan Dosya

Daha sonra **GetTempPathA** API’ni kullanarak **Temp** klasörünün yolunu alıyor ve buraya **CreateDirectoryA** kullanılarak **3582-490** adında bir klasör oluşturuluyor. Bu isim Neshta ailesinin diğer örneklerinde de kullanıldığından ailenin karakteristik özelliği olarak nitelendirilmektedir. Ardından buraya **CreateFileA** ile neshta.exe adında bir dosya oluşturuluyor.



Şekil 9 – Enfekte Edilmiş Uygulama Yapısı

Sonra zararlı yazılım, başta enfekte edilmiş kurban dosyanın orijinal yapısını geri yüklemek amacıyla birkaç işlem yapıyor. Bunun için işaretçisini **SetFilePointer** kullanarak zararlı kodun yer aldığı bölümün sonuna konumlandırıyor. Bu noktadan sonraki içerik okunarak **Temp** altında oluşturulan dosyanın içerisine **WriteFile** ile yazdırılıyor. Bu süreç sonucunda elde edilen dosya, enfeksiyon öncesindeki temiz kurban dosyanın birebir kopyasıdır.

75D3103	8BFF	mov edi,edi	CreateProcessW
75D3103	55	push ebp	
75D3104	8BEC	mov ebp,esp	
75D3104	6A 00	push 0	
75D3104	FF75 2C	push dword ptr ss:[ebp+2C]	[ebp+2C]:L"C:\\Users\\...\\Desktop"
75D3104	FF75 28	push dword ptr ss:[ebp+28]	
75D3104	FF75 24	push dword ptr ss:[ebp+24]	
75D3104	FF75 20	push dword ptr ss:[ebp+20]	
75D3105	FF75 1C	push dword ptr ss:[ebp+1C]	
75D3105	FF75 18	push dword ptr ss:[ebp+18]	
75D3105	FF75 14	push dword ptr ss:[ebp+14]	[ebp+14]:L"C:\\Users\\...\\AppData\\Local\\Temp\\3582-490\\neshta.exe" "
75D3105	FF75 10	push dword ptr ss:[ebp+10]	[ebp+10]:L"C:\\Users\\...\\AppData\\Local\\Temp\\3582-490\\neshta.exe"
75D3105	FF75 0C	push dword ptr ss:[ebp+0C]	
75D3105	FF75 08	push dword ptr ss:[ebp+08]	
75D3106	6A 00	push 0	[ebp+8]:"MZP"
75D3106	E8 CA2B0100	call <kernel32.CreateProcessIntern	
75D3106	5D	pop ebp	
75D3106	C2 2800	ret 28	

Şekil 10 – Temiz Dosyanın Çalıştırılması

Daha sonra kullanıcının şüphelenmesini önlemek amacıyla temiz dosya çalıştırılmaktadır.

75D35D8	8BFF	mov edi,edi	CreateFileA
75D35D8	55	push ebp	
75D35D8	8BEC	mov ebp,esp	
75D35D8	51	push ecx	
75D35D8	51	push ecx	
75D35D8	FF75 08	push dword ptr ss:[ebp+8]	[ebp+8]:C:\\windows\\svchost.com"
75D35D8	8D45 F8	lea eax,dword ptr ss:[ebp-8]	eax:C:\\windows\\svchost.com"
75D35D8	50	push eax	eax:C:\\windows\\svchost.com"
75D35D8	E8 A1EAF0FF	call <kernel32.Basep8BitStringToob	
75D35D8	85C0	test eax,ecx	
75D35D8	0F84 24990200	je kernel32.75D5F6F5	
75D35D8	56	push esi	
75D35D8	FF75 20	push dword ptr ss:[ebp+20]	
75D35D8	FF75 1C	push dword ptr ss:[ebp+1C]	
75D35D8	FF75 18	push dword ptr ss:[ebp+18]	
75D35D8	FF75 14	push dword ptr ss:[ebp+14]	
75D35D8	FF75 10	push dword ptr ss:[ebp+10]	
75D35D8	FF75 0C	push dword ptr ss:[ebp+0C]	
75D35D8	FF75 FC	push dword ptr ss:[ebp-4]	
75D35D8	E8 8B2FFFFF	call <kernel32.CreateFileW>	
75D35D8	8B00	mov esi,eax	eax:C:\\windows\\svchost.com"
75D35D8	8D45 F8	lea eax,dword ptr ss:[ebp-8]	[ebp-8]:C:\\windows\\svchost.com"
75D35D8	50	push eax	eax:C:\\windows\\svchost.com"
75D35D8	FF15 7005D375	call <kernel32.FreeUnicode	
75D35D8	8BC6	mov eax,esi	eax:C:\\windows\\svchost.com"
75D35D8	5E	pop esi	

Şekil 11 – C:\Windows\svchost.com Oluşturulması

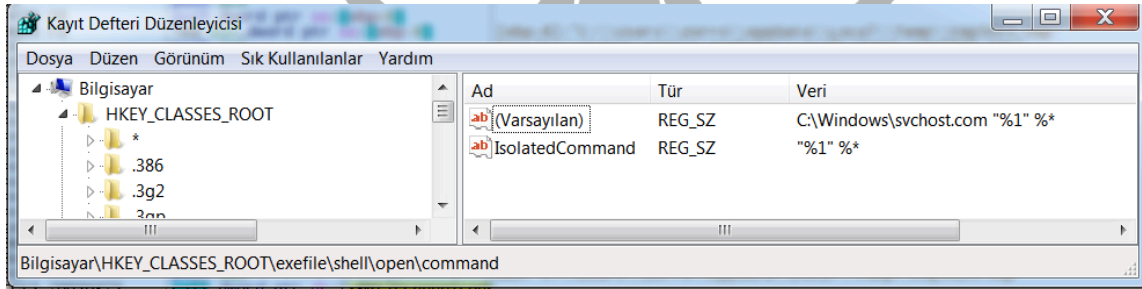
Bu noktadan sonra zararlı eğer yönetici yetkisi ile çalıştırıldıysa C:\Windows altında da svchost[.]com isminde bir dosya oluşturuyor ve kendisini ham haliyle bu dosyaya yazıyor.

Şekil 12 - C:\Windows\svchost.com Çalıştırılması

Ardından bu yeni oluşturulan svchost[.]com dosyası çalıştırılıyor.

Şekil 13 – Registry Key Oluşturulması

Bu işlemlerin ardından, sistemde hangi exe uzantılı dosya çalıştırılırsa çalıştırılsın önce svchost[.]com çalıştırılacak şekilde bir registry key ekleniyor.



Şekil 14 – Her EXE Uzantılı Dosya Çalıştırıldığında svchost[.]com Dosyasını Çalıştıracak Key

Bu eklenen key sayesinde her exe uzantılı dosya çalıştırıldığında svchost[.]com da çalıştırılıyor.

75A6E306	8BFF	mov edi,edi	FindFirstFileA
75A6E310	55	push ebp	
75A6E311	8BEC	mov ebp,esp	
75A6E313	5D	pop ebp	
75A6E314	EB 05	jmp <JMP.&FindFirstFileA>	
75A6E316	90	nop	
75A6E317	90	nop	
75A6E318	90	nop	
75A6E319	90	nop	
75A6E31A	90	nop	
75A6E31B	FF25 640AA675	jmp dword ptr ds:[<&FindFirstFileA>]	JMP.&FindFirstFileA
75A6E321	6A 00	push 0	
75A6E323	68 08020000	push 208	
75A6E328	8D85 F4DFFFFF	lea eax,dword ptr ss:[ebp-20C]	
75A6E32E	50	push eax	
75A6E32F	6A 02	push 2	
75A6E331	83E3 FC	and ebx,FFFFFFFFC	
75A6E334	53	push ebx	
75A6E335	E8 B234FFFF	call <JMP.&GetCurrentProcess>	

Şekil 15 – Dosya Taraması

Daha sonra zararlı, bütün dizinleri gezerek bulduğu exe uzantılı dosyaların üzerine kendisini yazmaya başlıyor. Bunun için **FindFirstFileA** ve **FindNextFileA** API'ları kullanılarak sistemde bulunan dizinler taranmaya başlanıyor.

75A65D86	8BFF	mov edi,edi	CreateFileA
75A65D88	55	push ebp	
75A65D89	8BEC	mov ebp,esp	
75A65D8B	51	push ecx	
75A65D8C	51	push ecx	
75A65D8D	FF75 08	push dword ptr ss:[ebp+8]	
75A65D8E	8D45 F8	lea eax,dword ptr ss:[ebp-8]	
75A65D90	50	push eax	
75A65D91	E8 A1EAF7FF	call <kernel32.75A8F6F5>	
75A65D92	85C0	test eax,eax	
75A65D93	0F84 24990200	je kernel32.75A8F6F5	
75A65D94	56	push esi	
75A65D95	FF75 20	push dword ptr ss:[ebp+20]	
75A65D96	FF75 1C	push dword ptr ss:[ebp+1C]	
75A65D97	FF75 18	push dword ptr ss:[ebp+18]	
75A65D98	FF75 14	push dword ptr ss:[ebp+14]	

Şekil 16 – Dosyanın Okunmak İçin Açılışı

Bir klasörlerde exe uzantılı bir dosyayla karşılaşıldığında dosyayı okuma amacıyla **CreateFile** API'ı ile açıyor.

75A63F76	6A 0C	push 12	ReadFile
75A63F77	68 4840A675	push kernel32.75A64048	
75A63F78	E8 DBD5FFFF	call kernel32.75A615CC	
75A63F79	8B7D 14	mov edi,dword ptr ss:[ebp+14]	
75A63F7A	85FF	test edi,edi	
75A63F7B	74 03	je kernel32.75A63FFB	
75A63F7C	8327 00	and dword ptr ds:[edi],0	
75A63F7D	8B75 08	mov esi,dword ptr ss:[ebp+8]	
75A63F7E	83FE F4	cmp esi,FFFFFFFF4	
75A64001	0F84 98B10200	je kernel32.75A8F1A2	
75A64002	83FE F5	cmp esi,FFFFFFFF5	
75A64003	0F84 7EB10200	je kernel32.75A8F18E	
75A64004	83FE F6	cmp esi,FFFFFFFF6	
75A64005	0F84 61B10200	je kernel32.75A8F17A	
75A64006	8BC6	mov eax,esi	
75A64007	25 03000010	and eax,10000003	
75A64008	83F8 03	cmp eax,3	
75A64009	0F84 80B10200	je kernel32.75A8F1B6	
75A6400A	FF75 18	push dword ptr ss:[ebp+18]	
75A6400B	57	push edi	
75A6400C	FF75 10	push dword ptr ss:[ebp+10]	

Şekil 17 – Dosyanın Okunması

Ardından dosyada gerçekten **MZ** başlığı var mı diye kontrol etmek amacıyla **ReadFile** API'ı ile dosyayı okuyor.

75A65D86	8BFF	mov edi,edi	CreateFileA
75A65D88	55	push ebp	
75A65D89	8BEC	mov ebp,esp	
75A65D8B	51	push ecx	
75A65D8C	51	push ecx	
75A65D8D	FF75 08	push dword ptr ss:[ebp+8]	
75A65D8E	8D45 F8	lea eax,dword ptr ss:[ebp-8]	
75A65D8F	50	push eax	
75A65D90	E8 A1EAF	call kernel32.Basep8BitStringToDynamic	eax:"C:\\MSOCache\\ALLUSE~1\\{90440~1\\setup.exe"
75A65D91	85C0	test eax,eax	eax:"C:\\MSOCache\\ALLUSE~1\\{90440~1\\setup.exe"
75A65D92	0F84 24990200	je kernel32.75A8F6F5	
75A65D93	56	push esi	
75A65D94	FF75 20	push dword ptr ss:[ebp+20]	[ebp+20]: "setup.exe"
75A65D95	FF75 1C	push dword ptr ss:[ebp+1C]	
75A65D96	FF75 18	push dword ptr ss:[ebp+18]	

Şekil 18 – Dosyanın Yazma Amacıyla Açılması

Daha sonra bu sefer yazma amacıyla dosya tekrar açılıyor.

```
Varsayılan (stdcall)
1: [esp+4] 000001F4
2: [esp+8] 0040A698 "MZP"
3: [esp+C] 0000A200
4: [esp+10] 001858FC
5: [esp+14] 00000000
```

Şekil 19 – WriteFile call stack

[esp+4]	hFile	Yazılacak dosyayı tutan handle
[esp+8]	lpBuffer	Yazılacak verinin bulunduğu adres
[esp+C]	nNumberOfBytesToWrite	Yazılacak byte sayısı (~40,5 KB)
[esp+10]	lpNumberOfBytesWritten	Yazılan byte sayısının yazılacağı adres
[esp+14]	lpOverlapped	NULL → senkron (blocking) yazma

Ardından **WriteFile** ile dosyaya yazma işlemi yapılıyor. WriteFile API çağrısı sırasında stack üzerinde yer alan parametrelerden, yazılan veri boyutunun 0xA200 (~40,5 KB) byte olduğu görülmektedir. Bu svchost.com dosyasının boyutuyla aynıdır.

Sistemde bulunan bütün .exe dosyaları için bu işlem tekrarlanıyor. Ardından dosya kapanıyor. Bu aşamaya kadar gerçekleştirilen analizde, zararlı yazılımın doğrudan bir veri sızdırma veya ağ üzerinden iletişim kurma davranışı sergilediğine dair herhangi bir bulguya rastlanmadı. Ancak kalıcılığı ve meşru dosyaları enfekte edebilmesi nedeniyle, ek bileşenlerle birlikte kullanıldığında daha kapsamlı ve zararlı faaliyetlere yol açabilir.

Temp'e Bırakılan Dosyanın Analizi

Adı	neshta.exe
MD5	562F69643012FCF6D235EBECBBEEA152
SHA256	bb349e47e07df566014d6acfb0525d8e7ec6e2c3288f3f706b5decfb7570273
Dosya Türü	PE32/EXE

Property	Value
File Name	C:\Users\...AppData\Local\Temp\3582-490\neshta.exe
File Type	Portable Executable 32
File Info	Microsoft Visual C++ 8
File Size	922.00 KB (944128 bytes)
PE Size	922.00 KB (944128 bytes)

Şekil 20 – Temp Altındaki neshta.exe'nin Statik Analiz Çıktısı

Oluşturulan exe'ye statik analiz araçları ile baktığımızda File ve PE boyutları uyuşmakta ve C++ ile yazıldığı gözükmemektedir.

neshta.exe

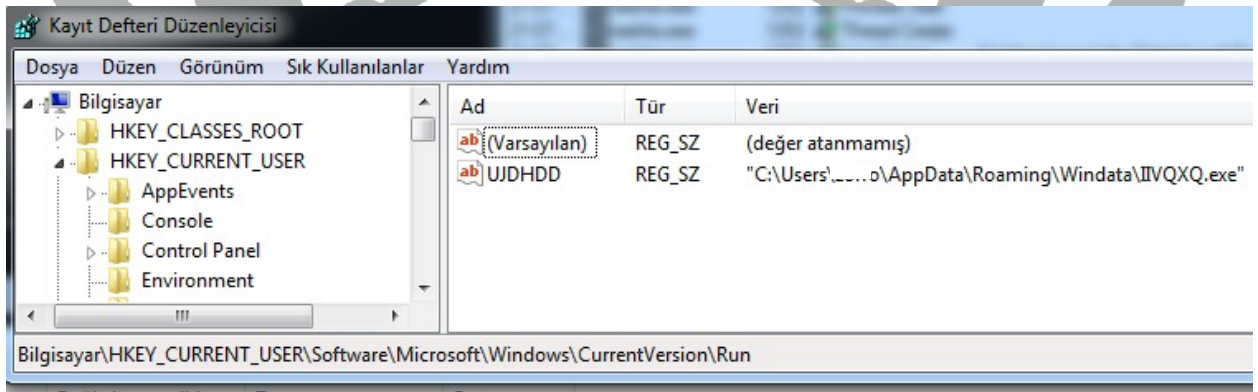
Şekil 21 – Barındırdığı Autolt scripti

Ayrıca bu yeni dosyada bizi 42.45KB boyutunda bir **Autolt** scripti karşılamaktadır.

MD5	ca096b71375b994b5c88a3b7bb72ac65
SHA256	da503a34168b3c21d9884a14b427fef614820a9fa82ae5f76f6e09df5474c2f5

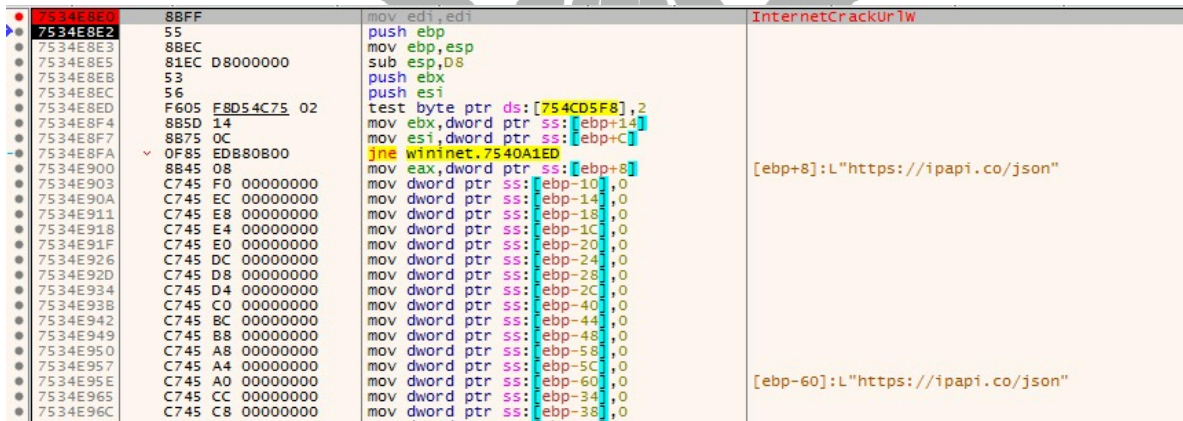
Şekil 22 – IIQVQ.exe Oluşturulması

Hex olarak bir dosyaya kopyalayıp legal bir Autolt aracı ile exe versiyonunu elde ediyoruz. Bu script, Temp altındaki dosyanın bir kopyasını **IIQVQ.exe** adıyla “Roaming\Windata” altına kopyalamaktadır.



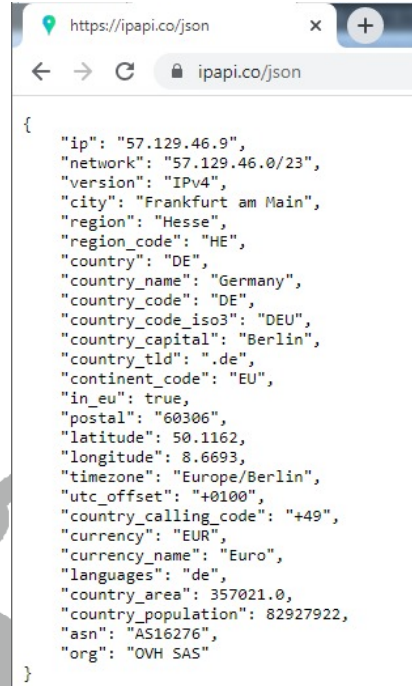
Şekil 23 – Eklenen Registry Run Key

neshta.exe de sistem her başlatıldığında **IIQVQ.exe** dosyasını çalıştıracak şekilde bir registry run key oluşturmaktadır.



Şekil 24 – İstek Atılan Domain

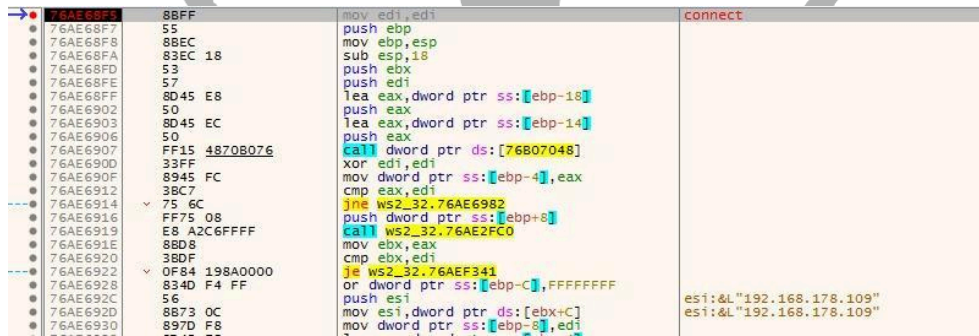
Malware, InternetCrackUrIw API'sini kullanarak https://ipapi.co/json URL'sini protokol, domain ve path gibi bileşenlerine ayırmakta ve ardından bu adrese HTTP/HTTPS isteği göndermektedir.



```
{
  "ip": "57.129.46.9",
  "network": "57.129.46.0/23",
  "version": "IPv4",
  "city": "Frankfurt am Main",
  "region": "Hesse",
  "region_code": "HE",
  "country": "DE",
  "country_name": "Germany",
  "country_code": "DE",
  "country_code_iso3": "DEU",
  "country_capital": "Berlin",
  "country_tld": ".de",
  "continent_code": "EU",
  "in_eu": true,
  "postal": "60306",
  "latitude": 50.1162,
  "longitude": 8.6693,
  "timezone": "Europe/Berlin",
  "utc_offset": "+0100",
  "country_calling_code": "+49",
  "currency": "EUR",
  "currency_name": "Euro",
  "languages": "de",
  "country_area": 357021.0,
  "country_population": 82927922,
  "asn": "AS16276",
  "org": "OVH SAS"
}
```

Şekil 25 – Hedef Sitenin İçeriği

Bu hedefi ziyaret ettiğimizde IP adresinden ülke, şehir, ASN, ISP, timezone gibi bilgileri veren bir IP-geolocation servisi olduğunu görüyoruz. Zararlı yazılımlar bu ücretsiz ve networkte zararsız gibi görünen adresi, geo-targetting (farklı konumlar için farklı davranışlar göstermek) amacıyla kullanabilir.



Address	Disassembly	Comment
76AE68F7	8BFF	mov edi,edi
76AE68F8	55	push ebp
76AE68F9	8BEC	mov ebp,esp
76AE68FA	83EC 18	sub esp,18
76AE68FD	53	push ebx
76AE68FE	57	push edi
76AE68FF	8D45 E8	lea eax,dword ptr ss:[ebp-18]
76AE6902	50	push eax
76AE6903	8D45 EC	lea eax,dword ptr ss:[ebp-14]
76AE6906	50	push eax
76AE6907	FF15 4870B076	dword ptr ds:[76B07048]
76AE690D	33FF	xor edi,edi
76AE690F	8945 FC	mov dword ptr ss:[ebp-4],eax
76AE6912	3BC7	cmp eax,edi
76AE6914	75 6C	jne ws2_32.76AE6982
76AE6916	FF75 08	push dword ptr ss:[ebp+8]
76AE6919	E9 A2C6FFFF	jmp ws2_32.76AE2FC0
76AE691E	8BD8	mov ebx,eax
76AE6920	3BD5	cmp ebx,edi
76AE6922	75 32	jne ws2_32.76AEF341
76AE6928	834D F4 FF	or dword ptr ss:[ebp-C],FFFFFFFF
76AE692C	56	push esi
76AE692D	8B73 0C	mov esi,dword ptr ds:[ebx+C]
76AE6930	897D F8	mov dword ptr ss:[ebp-8],edi

Şekil 26 – Local Hedefe Atılan İstek

Analizin devamında dosya, local bir IP adresine doğru sürekli ağ trafiği oluşturuyor ve her istek ile source port numarasını ardışık olarak arttırmaktadır. Oluşturulan bu yapay ağ gürültüsü, hem sistemde olağan dışı bir ağ hareketliliği yaratarak dikkat dağıtmayı hem de zararlının çalışma ortamını analiz ederek savunma veya analiz araçlarının varlığını tespit etmeyi hedefleyen bir savunma atlatma (defense evasion) tekniği olarak değerlendirilebilir.

YARA Kuralı

```
import "hash"
rule matched_neshta
{
  meta:
    author = "Bilge KELESOGLU - ZAYOTEM"
    description = "Neshta"
    report_date = "04.01.2025"
    file_name = "Light Tool V9.exe"

  strings:
    $neshta = "Neshta"
    $neshtahex = {4E 65 73 68 74 61}
    $original_file = " Light Tool V9"
    $dropped = "svchost.com"
    $mutex = "+^p.Ç°āW.Ě."
    $directory = "3582-490"
    $domain = "ipapi.co/json"

  condition:
    hash.md5(0, filesize) == "10812383882408c1d898b07d29d6e940" or
    hash.md5(0, filesize) == "562f69643012fcf6d235ebecbbeeA152" or
    hash.md5(0, filesize) == "ca096b71375b994b5c88a3b7bb72ac65" or
    hash.md5(0, filesize) == "dbab013a95d8f47e05e61e3eb9b9da0b" or
    $neshta or $neshtahex or
    (
      $directory and
      $domain and
      ( $mutex or $dropped or $original_file )
    )
}
```

MITRE ATTACK TABLE

Reconnaissance	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	C&C	Exfiltration
T1083 – File and Directory Discovery	T1204.002 – User Execution: Malicious File	T1546.001 – Change Default File Association	T1078 Valid Accounts	T1036 – Masquerading	T1078 – Valid Accounts	T1071.001 – Application Layer Protocol (Web)	-
T1033 – System Owner/User Discovery		T1112 – Modify Registry		T1112 – Modify Registry			
		T1554 – Compromise Host Software Binary		T1027 – Obfuscated Files or Information			

Çözüm Önerileri

1. Sistem üzerinde en az bir tane güncel ve güvenilir antivirüs yazılımı bulundurulmalıdır.
2. Kullanılan uygulamalar lisanlı ve güncel olmalıdır.
3. İşletim sistemi güvenlik güncellemeleri düzenli olarak yüklenmelidir.
4. Güvenilmeyen web sitelerinden dosya indirilmemelidir.
5. İnternette indirilen yazılımlar taramalıdır.
6. Kaynağı bilinmeyen uygulamalara yönetici izni verilmemelidir.
7. Aynı dosyanın birden fazla kendiliğinden oluşması şüpheli kabul edilmelidir.
8. Sistem üzerinde beklenmeyen yavaşlama veya hata durumlarında kapsamlı sistem taraması yapılmalıdır.
9. Bilgisayar düzenli aralıklarla yeniden başlatılarak sistem davranışı gözlemlenmelidir.
10. Önemli dosyalar düzenli olarak yedeklenmelidir.

HAZIRLAYAN

Bilge KELEŞOĞLU

[Linkedin](#)

